FAPI 2.0 compliance — the complete spec pack

What must be followed to claim a system is **fully FAPI 2.0 compliant**. Anchored on the FAPI 2.0 Security Profile **Final** (approved by OIDF membership, published 2025-02-22); the final conformance tests + certification path opened 2025-07. Status column maps this stack (`fapi2-design.md` I3) to each document.

1 · The two FAPI 2.0 final specifications

#	Spec	Status	Role
1	FAPI 2.0 Security Profile	**Final**, 2025-02-22	THE profile: all `shall`s a compliant AS / client / RS must meet
2	FAPI 2.0 Attacker Model	**Final**, 2025-02-22	Security goals the profile is formally proven against (A1, A1a, A2, A3a, A4, A5)

Everything else below is referenced *by* the Security Profile's §9 normative references — following the profile means following these.

2 · Normative base (profile §9 references)

#	Spec	Link	Required because	This stack
3	OAuth 2.0 Authorization Framework	RFC 6749	base protocol; `response_type=code` only	✔ **ok**
4	OAuth 2.0 Bearer Token Usage	RFC 6750	tokens in header only (never query); RS error semantics (3.1)	✔ **ok** header-only
5	PKCE	RFC 7636	**S256 mandatory**, fresh challenge per flow, bound to client+UA	✔ **ok** S256 enforced
6	OAuth 2.0 Security Best Current Practice (BCP 240)	RFC 9700	profile explicitly follows it; no open redirectors (4.11), no 307 (4.12), code reuse	✔ **ok**
7	OAuth 2.0 Authorization Server Metadata	RFC 8414	discovery is the only allowed endpoint source (clients shall NOT hardcode)	✔ **ok**
8	OAuth 2.0 Issuer Identification	RFC 9207	`iss` in every authorization response (success + error); mix-up defence	✔ **ok** both
9	Pushed Authorization Requests	RFC 9126	authorization **only** via authenticated PAR; plain authorize requests rejected; `request_uri` ≤ 600 s	✔ **ok** 120 s
10	Mutual-TLS Client Authentication & Certificate-Bound Tokens	RFC 8705	mTLS client auth (`tls_client_auth`) and/or mTLS sender-constrained tokens; `mtls_endpoint_aliases` , `use_mtls_endpoint_aliases`	✔ **ok** supported

#	Spec	Link	Required because	This stack
11	DPoP	RFC 9449	DPoP sender-constrained tokens; servers shall support **auth-code binding to DPoP key** (10.1) + nonce mechanism (§8)	✔ **ok** (incl. nonce, `htm/htu/ath/jti`)
12	TLS recommendations (BCP 195)	BCP 195 (RFC 7525 / RFC 9325 line)	TLS 1.2+ everywhere; server→server cipher restriction; keep current within 12 months of new BCP195	✔ **ok** policy
13	JWT BCP (BCP 225)	RFC 8725	only `PS256` / `ES256` / `EdDSA(Ed25519)`; never `none`; aud/typ discipline	✔ **ok** PS256/ES256
14	Service Identity in TLS	RFC 9525	TLS server-certificate identity verification	✔ **ok**
15	OpenID Connect Core 1.0 (errata 1)	OIDC Core	REQUIRED **iff** the AS returns the user's identity (id_token); `private_key_jwt` is specified in §9	✔ **ok** optional per plan
16	OpenID Connect Discovery 1.0 (errata 1)	OIDC Discovery	`/.well-known/openid-configuration` metadata distribution	✔ **ok**
17	OAuth 2.0 for Native Apps (BCP 212)	RFC 8252	only http loopback redirect exception rule	n/a (web/partner)
18	HSTS	RFC 6797	no TLS-stripping on browser endpoints	✔ **ok**
19	CORS protocol (WHATWG)	fetch spec, CORS	authorization endpoint **shall not** support CORS	✔ **ok**
20	OAuth DCR + management	RFC 7591, RFC 7592	the `jwks` /metadata model the profile builds client-key handling on	✔ **ok** (static reg)
21	CAA	RFC 8659	`should`: mitigate rogue DV cert issuance	● **todo** ops
22	DNSSEC	—	`should` against DNS spoofing	● **todo** ops
23	ISO/IEC 29100 privacy framework	ISO 29100	terms + privacy considerations baseline	● **todo** compliance

Mandatory numeric & behavioural shalls (profile §5, easy to miss)

- Authorization code lifetime ≤ **60 s**; PAR `request_uri` expiry < **600 s**; code single-use.
- `aud` in `private_key_jwt` assertions = **issuer identifier as a plain string** (arrays rejected).
- JWT `iat` / `nbf`: accept 0–10 s in future, reject > **60 s** in future (clock-skew rule).
- Client auth: **mTLS** (RFC 8705 §2) **or** `private_key_jwt` — nothing else; confidential clients only; password grant refused.
- Refresh-token rotation **prohibited** except for infra migration (old token must stay retry-able for a limited window).
- Sender-constrained tokens: **mTLS or DPoP** (at least one), on AS + client + RS.
- RS: verify validity/integrity/expiry/**revocation**, fail closed; never accept tokens in query.
- RSA keys ≥ **2048** bit; EC ≥ **224** bit; machine credentials ≥ **128 bit** entropy.
- `should`: least-privilege scopes; JWKS without duplicate `kid`s; no `x5u` / `jku` headers.

3 · Optional extensions of the FAPI 2.0 framework (not required for the base claim)

Spec	Link	When needed
FAPI 2.0 Message Signing	ID1 (proposed final; certification live 2025-07)	ecosystems/A5-replay defence via RFC 9421 request signing
Rich Authorization Requests	RFC 9396	recommended when `scope` can't express the grant — **this system uses RAR** for payout/KYC details
JWT profile for OAuth 2.0 access tokens	RFC 9068	informative; if AS issues JWT ATs
CIBA (OIDC backchannel)	CIBA Core	only if the decoupled flow is used
OAuth 2.0 Step-Up Authentication Challenge	RFC 9470	**this system uses it for money movement / KYC decisions**
OIDC Back-Channel Logout	1.0	**this system wires IdP disable → immediate session end**

4 · How compliance is proven

1. **Conformance suite** (free, certification.openid.net) — final FAPI 2.0 Security Profile test plans for **AS** and **client** roles since 2025-07-09; DPoP supported; OIDC (`openid` scope / id_token) optional in the tests (run the variant you support).
2. **Official certification** — instructions: two registered clients (separate keys/certs — mix-up tests), redirect URLs `https://www.certification.openid.net/test/a/<alias>/callback` (+ the `?dummy1=lorem&dummy2=ipsum` variant), plus a resource-server GET endpoint for certificate-binding tests.
3. **Formal analysis** — the profile is proven secure under the attacker model (Hosseyni/Küsters/Würtele 2024); implementations should deploy on *certified* bases and keep BCP195 current.

5 · Deviation risks to watch in this stack (from the Feb-2025 final)

- `aud` = issuer *string* (final change) — confirm the gateway/IdP client assertions.
- `request_uri` single-use enforcement must happen **at authorization time**, not page load.
- No refresh-token rotation in the portals' session refresh path (gateway refresh must reuse the same bound refresh token).
- DPoP `htu` behind nginx must come from `X-Forwarded-Host` (already flagged in fapi2-design §One fix).